BioSpecInfo

Security, Privacy & Compliance — BioSpecInfo

Samuele Pio Provenzano

Versione **bsi-v230** · commit `e7bbda2`

Generato il 2026-10-23

Documento generato automaticamente dal sorgente Markdown versionato nel repository. La versione e il commit stampati in ogni piè di pagina identificano esattamente lo stato del software descritto.

Security, Privacy & Compliance — BioSpecInfo

Field	Value
Software	BioSpecInfo
Author	Samuele Pio Provenzano
Model	Client-side / Local-First PWA

1. Privacy & data protection (GDPR)

1.1 Local-First by design

- **No account, no login, no advertising tracking.**
- All user data (drawn molecules, preferences, quiz history, study progress) is

stored **exclusively locally** on the device (`localStorage` / IndexedDB / `sql.js`), with no transmission to author-controlled servers.

- **There is no application backend** collecting or processing personal data.

1.2 Data handling and GDPR alignment

- **Data minimisation:** the app requires no personal data to function.
- **No transfer to the author's third parties:** data never leaves the device for

infrastructure controlled by the author.

- **Optional, transparent external calls:** only upon a user action (searching a

molecule, opening a 3D model) does the app query public third-party APIs (PubChem, NASA/ESA, spectral databases). Such requests contain **only the chemical identifier** (e.g. SMILES/name) and **no personal data**. Use of these services is subject to their respective privacy policies.

- **Local right to erasure:** the user can delete data by clearing the site

storage in the browser.

> **Note.** This alignment describes the local-first design properties that favour GDPR compliance. It does not constitute a legal certification; for regulated contexts a dedicated DPIA assessment is recommended.

2. Application security (OWASP)

2.1 Attack surface

Being a **static application with no backend**, entire classes of server-side vulnerabilities are absent by construction (SQL injection on a server DB, server-side RCE, server authentication/session, IDOR on proprietary APIs).

2.2 Input sanitisation

- Parsing of **SMILES / SMARTS** strings and molecular files is delegated to

RDKit MinimalLib (WASM), which validates the structures and rejects malformed input by returning invalid molecules rather than executing them.

- Strings coming from user input or external APIs, when inserted into the DOM,

are treated as untrusted. Their textual value (names, notations) is shown as text content/ `textContent` or with escaping of the `& < >` characters.

2.3 Runtime robustness

- **`localStorage` guard:** every storage access is protected by `try/catch` with

an in-memory fallback, so that incognito mode or blocked storage cannot halt execution (a historical regression that has been fixed).

- **Controlled degradation:** panels never silently stay empty; errors show a

message and, where applicable, a "Retry" button.

- **Sub-app isolation** in `iframe`s.

2.4 Content Security Policy (deployment recommendation)

Since the app can be published on static hosting, it is recommended to serve it with security headers at the hosting/CDN level:

- Restrictive `Content-Security-Policy` (self script/style + WASM),

`frame-ancestors`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: no-referrer`.

- `Cross-Origin-Opener-Policy` / `Cross-Origin-Embedder-Policy` if

`SharedArrayBuffer` and parallel Web Workers are enabled in the future (HPC roadmap).

---

3. Integrity and reproducibility (GAMP 5 alignment)

For use in pharmaceutical/regulated contexts, the architecture is **compatible** with GAMP 5 principles:

- **Determinism:** the cheminformatics computations (RDKit) are deterministic and

reproducible for the same input.

- **Version traceability:** code versioning on Git, versioned Service Worker cache, changelog.
- **Method transparency:** the heuristic predictors are documented with their sources and limitations (see the *Validation Report*).

> Again: this is **alignment with the principles**, not a formal qualification (IQ/OQ/PQ), which would require a dedicated validation process at the using organisation.

---

4. Summary

Aspect	Status
Personal data transmitted to author's servers	**None**
Backend / server database	**Absent**
Molecular input validation	RDKit WASM
DOM output escaping	Yes (untrusted content)
Storage guard / error degradation	Yes
CSP / security headers	Recommended at hosting level
Offline operation	Yes (Service Worker)